

ADA CASA AL1 Security Assessment Package

Sonave Cloud Application Security Verification (OWASP ASVS v4.0.3)

LETTER OF VALIDATION EVIDENCE

Application Name: Sonave

Primary Contact: Derek Gallardo
(DerekGallardo01@gmail.com)

Assessor / Lab: TAC Security (ESOF AppSec ADA CASA)

Requested Google Scopes: <https://www.googleapis.com/auth/meetings.space.readonly>,
<https://www.googleapis.com/auth/meetings.conference.media.readonly>

Production Endpoint: <https://usesonave.com>

Assessment Tier: CASA AL1 (Formerly Tier 2)

Target Deadline: November 20, 2026

1. System Architecture & Data Flow Narrative

Sonave is an AI voice authenticity and deepfake detection engine protecting Google Meet conference calls. The production application is hosted on Railway's containerized infrastructure fronted by Cloudflare CDN with strict TLS 1.3 encryption.

Data Protection & Privacy Boundary:

- Zero Third-Party Training:** User meeting audio and voiceprints are never transmitted to third parties or used to train external foundation models.
- Data Minimization:** Only requested media frames during active monitored meetings are processed.
- Ephemeral Buffering:** Audio buffers are scored in-memory and discarded unless the workspace owner requests archiving.
- Encrypted Volume Storage:** Persistent data resides on isolated Railway /data encrypted storage volumes.

2. Secrets Management & Key Protection

All cryptographic keys, OAuth secrets, and service tokens are injected strictly at runtime via environment variables:

Variable Name	Function	Security Control
SONAVE_SESSION_SECRET	HMAC-SHA256 session token signature	256-bit cryptographically secure entropy
SONAVE_GOOGLE_CLIENT_ID	Public OAuth Client ID	Whitelisted to https://usesonave.com origin
SONAVE_GOOGLE_CLIENT_SECRET	Google OAuth Client Secret	Server-side only; never exposed to browser
SONAVE_API_TOKEN	M2M Service Authentication	Evaluated using constant-time <code>secrets.compare_digest</code>

3. Identity, Authentication & Session Controls

- **Google OAuth 2.0:** Implemented via Authorization Code Grant with high-entropy cryptographic state nonces validated via HMAC on callback.
- **Cookie Security:** All session cookies enforce HttpOnly, Secure, and SameSite=Lax (with companion CHIPS SameSite=None; Partitioned cookies for Google Meet side-panel embedding).
- **Session Invalidation:** Logout triggers an atomic server-side session version increment (bump_session_ver) invalidating all tokens, while simultaneously revoking refresh tokens upstream at `oauth2.googleapis.com/revoke`.
- **Privileged Access:** Admin access requires Google Workspace authentication with 2-Step Verification (2SV / FIDO2) enforced.

4. Software Composition Analysis (SCA) & Dependency Audit

Automated dependency vulnerability scan executed using pip-audit against production dependencies (railway/requirements.txt):

```
{
  "dependencies_scanned": 19,
  "vulnerabilities_found": 0,
  "status": "PASSED (Clean Bill of Health)",
  "advisory_database": "PyPI Advisory DB & OSV",
  "audit_timestamp": "2026-09-01T16:20:10Z"
}
```

5. Security Logging, Monitoring & Audit Trail (OWASP ASVS V7)

Event Kind	Trigger Description	Security Scope
signup / signin	Google OAuth user authentication	Audit trail on user access
signout	Session invalidation & token revocation	Session lifecycle tracking
bot_created / bot_denied	Meeting monitor dispatch & policy check	Access control enforcement
incident_open / incident_ack	Voice spoof alert lifecycle	Deepfake threat forensics
ws: rejected disallowed origin	Cross-Origin WebSocket Hijacking attempt	CSWSH mitigation alert (Warning)
rate_limit_exceeded	Excessive authentication attempts	429 Brute-force throttling

6. Production Security Headers & Response Hardening

Live verification against production server `https://usesonave.com`:

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
X-Frame-Options: SAMEORIGIN (ALLOW-FROM meet.google.com for addon)
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: microphone=(self), camera=(), geolocation=(), payment=()
Cross-Origin-Opener-Policy: same-origin-allow-popups
Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline' https://accounts.google.com https://cdn.jsdelivr.net; ...
Cache-Control: no-store, no-cache, must-revalidate, private (on /console, /api/*, /auth/*)
Server Info: Removed (X-Powered-By header stripped; /docs & /redoc disabled)
```